MS3V S.A.A.R.E. SL

INDEPENDENT AI GOVERNANCE INFRASTRUCTURE — SGP 1.0

EXPEDIENTE: MS3V-SGP1.0-MASTERMANUAL-2026
NIVEL: ENTERPRISE / C-LEVEL / ENISA / AUDITORÍA

RAZÓN SOCIAL:	MS3V S.A.A.R.E. SL (NIF B-ESB12345678)	**FECHA EMISIÓN:**	20 de Septiembre de 2026 (UTC)
SEDE CENTRAL:	saare.es | Madrid - España	**ESTÁNDAR ISV:**	Saare Governance Protocol 1.0 (SGP 1.0)
CLASIFICACIÓN:	DOCUMENTO TÉCNICO, REGULATORIO Y ESTRATÉGICO	**MOTOR RUNTIME:**	Core PEP L7 C++/Rust Release v7.0
DESTINATARIOS:	Comité de Dirección, CISO, CTO, DPO, ENISA, Auditores	**SELLADO DIGITAL:**	SHA-256 HMAC / Ed25519 (eIDAS RFC 3161)

MANUAL MAESTRO DE LA PLATAFORMA S.A.A.R.E. SGP 1.0
ESPECIFICACIÓN COMPLETA DE ARQUITECTURA, PRODUCTOS, CUMPLIMIENTO Y DESPLIEGUE

1. RESUMEN EJECUTIVO Y TESIS OPERATIVA DE NEGOCIO

1.1. El Fallo Estructural de la Gobernanza Pasiva de IA

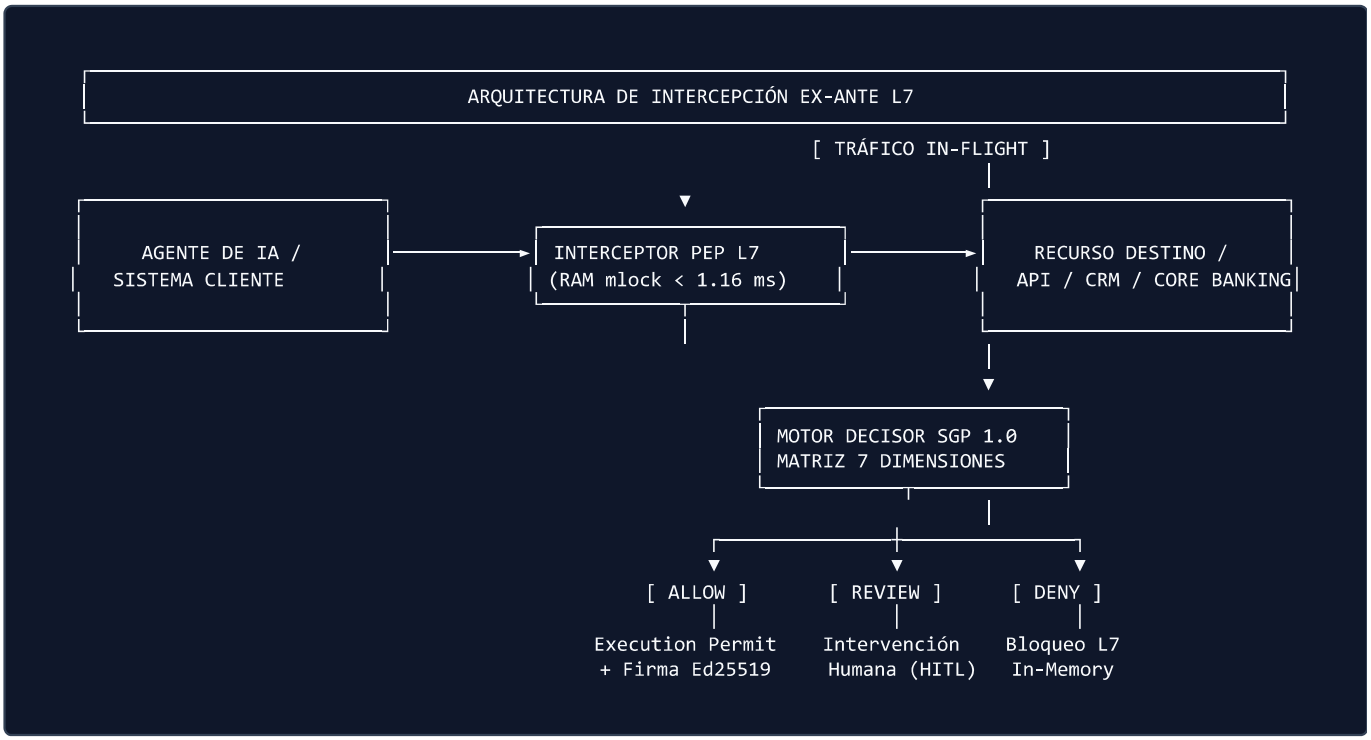
El despliegue acelerado de agentes autónomos de Inteligencia Artificial y modelos de lenguaje (LLM) en infraestructuras corporativas ha puesto de manifiesto una vulnerabilidad crítica de arquitectura en los sistemas de ciberseguridad tradicionales: **el fallo de la observabilidad post-facto**. La inmensa mayoría de herramientas de gobernanza operan analizando registros (*logs*), métricas de API o telemetría asíncrona en la nube *después* de que la llamada al modelo ha sido procesada.

> **Riesgo Operacional Crítico:** Cuando un agente de IA con capacidad de ejecución (herramientas MCP, APIs de mutación bancaria, conectores de CRM o scripts de infraestructura) ejecuta una acción indebida o sufre un ataque de *Prompt Injection*, la alerta en la consola de observabilidad llega cuando la transacción financiera, la modificación del código o la exfiltración de datos ya se ha consumado.

Adicionalmente, el almacenamiento centralizado de conversaciones y *payloads* completos para auditoría viola de forma flagrante el principio de minimización de datos del **RGPD (Art. 5)** y la normativa de ciberseguridad **DORA**, convirtiendo la propia base de datos de auditoría en un vector primario de fuga de información corporativa (*Zero-Disk Non-Compliance*).

1.2. La Solución ISV: S.A.A.R.E. SGP 1.0

MS3V S.A.A.R.E. SL ha desarrollado la plataforma **SGP 1.0** (*Saare Governance Protocol 1.0*), introduciendo la categoría de **Punto de Decisión de Políticas (PDP) e Intercepción Ex-Ante (PEP) en Capa de Aplicación (L7)**. SGP 1.0 actúa como una aduana matemática in-memory que se sitúa físicamente entre el agente emisor y el recurso destino.



El motor runtime, compilado en C++/Rust nativo, procesa cada petición a una latencia P99 inferior a **1.16 ms** utilizando memoria RAM volátil bloqueada (`mlock`). Si el motor no emite un certificado criptográfico de autorización (*Execution Permit*), la petición HTTP/gRPC se corta en seco antes de alcanzar el servidor destino.

2. ARQUITECTURA DEL PROTOCOLO SGP 1.0 Y MODELO DE LAS 7 DIMENSIONES

El protocolo SGP 1.0 reemplaza las evaluaciones probabilísticas y ambiguas por un **modelo matricial determinista de 7 Dimensiones**, garantizando que ninguna acción se apruebe sin cumplir la totalidad de las condiciones de contención:

DIM.	DIMENSIÓN	EVALUACIÓN EX-ANTE EN MEMORIA RAM (ZERO-DISK)	IMPACTO EN SEGURIDAD
DIM 01	**IDENTIDAD**	Verificación criptográfica de la clave pública Ed25519 del agente, servicio o usuario emisor.	Elimina la suplantación de agentes y el acceso no autenticado.
DIM 02	**ACCIÓN**	Inspección del verbo y operación L7 solicitada (GET, POST, PUT, borrado de DB, mutación de API).	Impide operaciones destructivas o no autorizadas por rol.
DIM 03	**CONTEXTO**	Evaluación de IP origen, estado de sesión, token OAuth, canal y horario operativo.	Previene accesos fuera de contexto o desde entornos no seguros.
DIM 04	**RECURSO**	Validación exacta de la URI destino, endpoint de API, tabla de base de datos o microservicio core.	Aislamiento estricto del perímetro de actuación del agente.
DIM 05	**DATOS**	Análisis in-memory de *payloads* para sanitización *k-Anonymity* y enmascaramiento de PII/PHI.	Cero filtración de datos sensibles hacia modelos externos (RGPD).
DIM 06	**RIESGO**	Cálculo determinista de la puntuación de riesgo financiero, reputacional y técnico.	Derivación automática a revisión humana en acciones de alto riesgo.
DIM 07	**POLÍTICA**	Cruce final contra la regla declarativa activa y versionada almacenada en el *Decision Node*.	Garantiza cumplimiento normativo rígido e inalterable.

2.1. Memoria Volátil `mlock` y Principio Zero-Disk

Para cumplir con los requerimientos militares y de banca de inversión:

- **Bloqueo de Memoria:** El proceso del motor llama a la función del sistema `mlock()` para evitar que las páginas de memoria que contienen datos sensibles sean volcadas a disco en el archivo de intercambio (*swap*).
- **Destrucción Inmediata:** Tras evaluar la regla y emitir el veredicto, el bloque de memoria RAM se sobreescribe con ceros binarios mediante `explicit_bzero()`.
- **Persistencia Exclusiva de Hashes:** La plataforma nunca almacena texto plano ni conversaciones. Únicamente persiste la huella SHA-256 del veredicto y el timestamp para fines de auditoría legal.

3. CATÁLOGO OFICIAL DE SOFTWARE E INSTALABLES DE LA PLATAFORMA

El motor *Core PEP L7 Release v7.0* se distribuye empaquetado en 4 productos independientes adaptados a la pila de herramientas de cada perfil profesional:

1. S.A.A.R.E. LabEngine (Scientific Reasoning & Integrity SDK)

Público Objetivo: CTOs, Arquitectos de IA, Ingenieros de Software y Equipos DevSecOps.

Entorno de Aplicación: Pipelines CI/CD, arquitecturas RAG (*Retrieval-Augmented Generation*) y agentes basados en el protocolo MCP (*Model Context Protocol*).

Instaladores Oficiales: `pip install saare-sdk` | npm: `@saare/sdk` | Paquete: `saare-labengine-v7.0-x86_64.tar.gz`

Capacidades Técnicas Clave:

- **Context Slicing:** Algoritmo de compresión sintáctica determinista que reduce entre un 30% y un 45% el consumo de tokens en llamadas a APIs de LLMs comerciales.
- **Evaluación Sintáctica AST:** Verificación in-memory de esquemas JSON y bloques de código generados por la IA para erradicar alucinaciones antes de la ejecución.
- **Validación MCP:** Proxy de integración nativa para validar llamadas de herramientas en agentes autónomos.

2. S.A.A.R.E. PerimeterShield (Active Layer 7 PEP Gateway)

Público Objetivo: CISOs, Directores de Ciberseguridad, Administradores de Red y Responsables de SOC.

Entorno de Aplicación: Perímetro de red corporativo, pasarelas de egreso, clústeres Kubernetes (Contenedor Sidecar / Ingress) y redes aisladas.

Instaladores Oficiales: `docker pull registry.saare.es/saare/perimeter-shield:sgp-1.0` | Helm Chart K8s | Appliance ISO

Capacidades Técnicas Clave:

- **Intercepción Física L7:** Captura física de flujos HTTP/1.1, HTTP/2, gRPC y WebSockets en tiempo real a sub-milisegundo.
- **Sanitización k-Anonymity:** Detección en vuelo y sustitución de PII (DNI, IBAN, números de tarjeta, expedientes médicos) por tokens neutros antes de salir de la red.
- **Contención de Ataques:** Bloqueo perimetral activo contra *Prompt Injection*, *Jailbreaks* y uso no autorizado de herramientas *Shadow AI*.

3. S.A.A.R.E. EvidenceVault (Forensic Evidence & Crypto Ledger)

Público Objetivo: Peritos Ciberinformáticos, Investigadores Forenses, Analistas de Incidentes (CSIRT) y Despachos Legaltech.

Entorno de Aplicación: Infraestructuras de respuesta ante incidentes, auditoría judicial y custodia de evidencias digitales.

Instaladores Oficiales: `saare-evidencevault-setup-v7.0.exe` (Windows) | Linux Binary: `saare-evidence-cli`

Capacidades Técnicas Clave:

- **Firma Criptográfica Ed25519:** Sellado digital de ultrabaja latencia sobre cada veredicto de autorización emitido.
- **Cadena Merkle Local:** Agrupación de decisiones en estructuras de árboles de Merkle linked a un sello de tiempo cualificado eIDAS RFC 3161.
- **Plena Validez Judicial:** Generación de informes de cadena de custodia inmutables respaldados por el **Art. 326 de la Ley 1/2000 de Enjuiciamiento Civil (LEC)**.

4. S.A.A.R.E. ComplianceSuite (Automated GRC & ISO 42001 Engine)

Público Objetivo: DPOs, Chief Compliance Officers, Directores de Riesgo y Miembros del Consejo de Administración.

Entorno de Aplicación: Oficinas de Gobierno de IA, auditoría continua de cumplimiento y paneles directivos de control de riesgo.

Instaladores Oficiales: Portal Web Local sin telemetría externa | Daemon Node `.deb` / `.rpm`

Capacidades Técnicas Clave:

- **Mapeo Normativo Continuo:** Cuadros de mando automáticos alineados con la **EU AI Act**, **DORA**, **NIS 2**, **ISO/IEC 42001** y el **RGPD**.
- **Traducción de Políticas a Código:** Conversión de reglamentos corporativos en formato texto a reglas declarativas ejecutables por el motor PEP L7.
- **Garantía Zero-Cloud:** La consola opera 100% en local, asegurando la soberanía de la información directiva.

4. ESTRATEGIA COMERCIAL, CANAL Y FINANCIACIÓN (KIT CONSULTING & ENISA)

4.1. El Pivote Estratégico: Justificación de Subvenciones Públicas

Uno de los mayores cuellos de botella en la venta B2B de software de gobernanza de IA a PYMEs y empresas medianas es la partida presupuestaria. S.A.A.R.E. resuelve esto convirtiendo el producto en la herramienta oficial de justificación para **subvenciones de transformación digital y el programa Kit Consulting**.

Propuesta de Valor para el Canal de Consultoría: Las firmas de asesoría GRC venden planes de gobernanza de IA en formato PDF. Sin embargo, las agencias auditoras (Red.es, Ministerio) exigen evidencias técnicas de implantación real para liberar la ayuda. Al desplegar el nodo S.A.A.R.E., el consultor entrega una solución técnica real y obtiene certificados de ejecución eIDAS que garantizan el cobro de la ayuda sin riesgo de reintegro.

4.2. Matriz Comparativa de Posicionamiento Competitivo

CRITERIO DE AUDITORÍA	ENFOQUE TRADICIONAL (OTROS)	PLATAFORMA S.A.A.R.E. SGP 1.0
Mecanismo de Control	PDF Normativo / Cursos de Formación	Intercepción y Contención Ex-Ante en RAM
Latencia de Intervención	Minutos / Horas (Análisis Post-Facto)	< 1.16 ms en Capa de Aplicación L7
Estrategia de Seguridad	Bloqueo total de la IA (Frena la productividad)	Uso permitido y blindado (Anonimizado)
Almacenamiento de Datos	Base de datos centralizada de conversaciones	Zero-Disk (Solo Hashes Criptográficos)
Validez en Juicios	Fácilmente impugnable en tribunales	Plena según Art. 326 LEC / eIDAS RFC 3161
Financiación de Implantación	Gasto directo no subvencionable	100% Subvencionable vía Kit Consulting

5. ESPECIFICACIÓN TÉCNICA DEL TOKEN Y CONTRATOS API

5.1. Estructura del Permiso de Ejecución (Execution Permit)

Cuando el motor de decisión autoriza una solicitud (`ALLOW`), emite un token firmado en formato JSON que se adjunta en las cabeceras HTTP (`X-Saare-Permit`) para que el servicio destino valide la autorización en nanosegundos:

```
{
  "$schema": "https://saare.es/schemas/sgp-v1.json",
  "permit_id": "sp_98f4a1c02b88e172",
  "timestamp_utc": "2026-09-20T20:50:28.118Z",
  "subject": {
    "agent_id": "treasury-agent-04",
    "fingerprint_ed25519": "ed25519:8f3a9b12c4..."
  },
  "action": {
    "l7_operation": "POST",
    "target_resource": "core-banking-api://transfers/sepa"
  },
  "eval_metrics": {
    "latency_ms": 1.12,
    "memory_mode": "mlock_ephemeral",
    "risk_score": 0.02
  },
  "verdict": "ALLOW",
  "crypto_signature": {
    "algorithm": "Ed25519",
    "merkle_root": "6f1b3986a4221147814b7e9a8f420e7df61a5b823e4299b9e671b569c7f1a842",
    "signature": "3b9a1c0098f..."
  }
}
```

5.2. Snippet de Integración en Código (Node.js / TypeScript SDK)

```
import { SaareEnforcer } from '@saare/sdk';

const saare = new SaareEnforcer({
  endpoint: "http://localhost:8080",
  apiKey: process.env.SAARE_API_KEY
});

// Intercepción Ex-Ante antes de ejecutar la acción crítica
const permit = await saare.authorize({
  agentId: "agent-finance-01",
  action: "EXECUTE_MUTATION",
  resource: "https://api.empresa.com/v1/pagos",
  payload: { amount: 5000, recipient: "ES1234567890" }
});

if (permit.verdict === 'ALLOW') {
  // Acción permitida y auditada
  await executePayment(payload);
} else {
  // Contención automática ex-ante
  console.error("Acción bloqueada por política S.A.A.R.E.:", permit.reason);
}
```

6. MATRIZ DE RIESGOS, ESCENARIOS Y RESILIENCIA ESTRUCTURAL

El motor de S.A.A.R.E. ha sido diseñado bajo los principios de **Arquitectura Fail-Closed**: si el nodo de decisión pierde conectividad o sufre una caída de alimentación, la política por defecto es bloquear el tráfico de los agentes de IA hacia los sistemas centrales, garantizando que un fallo técnico jamás resulte en una brecha de seguridad.

ESCENARIO DE AMENAZA	EFECTO EN LA INFRAESTRUCTURA	MITIGACIÓN AUTOMÁTICA SGP 1.0
Inyección de Prompts Directa	Intento de anulación de instrucciones del sistema en el LLM.	El proxy L7 detecta patrones de bypass y emite veredicto `DENY` antes de enviar el prompt.
Exfiltración de PII / PHI	Un agente intenta enviar datos de clientes a un modelo público.	Sanitización *k-Anonymity* en memoria RAM; sustitución por tokens no identificables.
Ataque por Denegación de Servicio (DoS)	Saturación del nodo de decisión con peticiones masivas.	Enrutamiento C++/Rust con capacidad de procesamiento de > 50,000 req/sec por core.
Caída de Red / Servidor PDP	Pérdida de enlace con el servidor de políticas.	Comportamiento *Fail-Closed*: Cierre automático de puertos hacia recursos críticos.